DIGITAL FORENSICS | MEMORY ANALYSIS | INCIDENT RESPONSE

Memory Forensics Case Study

Investigating a Cridex banking-trojan infection with Volatility

Shahad Mansour Alhazmi

Key findings

- **Two processes contain injected code:** explorer.exe (PID 1484) and reader_sl.exe (PID 1640, the Adobe Reader Speed Launcher). Both hold a PE image in private read-write-execute memory.
- **explorer.exe is the only process talking to the internet**, with connections to 41.168.5.140:8080 (South Africa) and 125.19.103.198:8080 (India).
- **The injected payloads are identified as Cridex** (a banking trojan with worm capabilities) by 60 of 72 and 61 of 72 antivirus engines on VirusTotal.
- **Banking-related strings** (Chase, TD Bank, Authorize.net) and a probable command-and-control URL on 188.40.0.138:8080 (Germany) were recovered from process memory.

1. Scenario and evidence

A manager opened an attachment from a spearphishing email and did not notice anything unusual. Some time later, unusual activity appeared in the company accounts. First responders captured a memory image of the suspected machine, and this report documents the analysis of that image with the Volatility Framework.

Item	Details
Evidence	project1-c.vmem, 536,870,912 bytes (a VMware memory image provided as a training sample)
Operating system	Windows XP SP3, x86 (Volatility profile WinXPSP3x86; imageinfo also suggested WinXPSP2x86)
Acquisition time	2012-07-22 02:45:08 UTC (2012-07-21 22:45:08 local, -0400)
Tools	Volatility Foundation Framework 2.6, Windows certutil, PowerShell, VirusTotal, ipinfo.io

2. Approach

- **Identify the system** with imageinfo, then list processes with several plugins (pslist, psscan, pstree, psxview, cmdline) to detect hidden or unusual processes.
- **Look inside process memory** with malfind, ldrmodules and dlllist for injected or hidden code.
- **Map network activity** with connections, connscan, sockets and sockscan, and correlate socket creation times with the incident timeline.
- **Extract and scan artifacts** with procdump and malfind -D, hash them with certutil, and check the hashes on VirusTotal.
- **Hunt for indicators** by dumping process memory (memdump) and extracting URLs and IP addresses with PowerShell regular expressions; enrich IP addresses with ipinfo.io.

3. Findings

3.1 Processes: nothing hidden, but injected code

pslist and psscan returned the same 17 processes, and psxview showed every process in all views, so **no process was hidden or unlinked**. The cmdline plugin showed legitimate paths for every process, with no misspelled or masquerading names. The suspicion therefore comes from memory content and behavior, not from names.

```
> vol -f project1-c.vmem --profile=WinXPSP3x86 pslist
Name                    PID   PPID   Thds   Hnds   Start (UTC)
System                    4      0     53    240
smss.exe                368      4      3     19   2012-07-22 02:42:31
csrss.exe               584    368      9    326   2012-07-22 02:42:32
winlogon.exe            608    368     23    519   2012-07-22 02:42:32
services.exe            652    608     16    243   2012-07-22 02:42:32
lsass.exe               664    608     24    330   2012-07-22 02:42:32
svchost.exe             824    652     20    194   2012-07-22 02:42:33
svchost.exe             908    652      9    226   2012-07-22 02:42:33
svchost.exe            1004    652     64   1118   2012-07-22 02:42:33
svchost.exe            1056    652      5     60   2012-07-22 02:42:33
svchost.exe            1220    652     15    197   2012-07-22 02:42:35
explorer.exe           1484   1464     17    415   2012-07-22 02:42:36
spoolsv.exe            1512    652     14    113   2012-07-22 02:42:36
reader_sl.exe          1640   1484      5     39   2012-07-22 02:42:36
alg.exe                 788    652      7    104   2012-07-22 02:43:01
wuauclt.exe            1136   1004      8    173   2012-07-22 02:43:46
wuauclt.exe            1588   1004      5    132   2012-07-22 02:44:01
```

Running malfind on the processes that stood out revealed the same pattern in two of them: a private memory region with **PAGE_EXECUTE_READWRITE** protection that starts with the bytes 4d 5a ("MZ"), the header of a Windows executable. A region that is writable, executable, not backed by a file on disk and contains a PE header is the classic signature of code injection.

Process	PID	Address	Protection	Content
explorer.exe	1484	0x01460000	PAGE_EXECUTE_READWRITE (private)	PE header (MZ)
reader_sl.exe	1640	0x003d0000	PAGE_EXECUTE_READWRITE (private)	PE header (MZ)

```
> vol -f project1-c.vmem --profile=WinXPSP3x86 malfind -p 1484
Process: explorer.exe Pid: 1484 Address: 0x1460000
Vad Tag: VadS Protection: PAGE_EXECUTE_READWRITE
Flags: CommitCharge: 33, MemCommit: 1, PrivateMemory: 1, Protection: 6
0x01460000  4d 5a 90 00 03 00 00 00 04 00 00 00 ff ff 00 00   MZ..............
0x01460010  b8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 00   ........@.......
```

The first 64 bytes of both regions are identical, which suggests that **the same payload was injected into both processes**. In explorer.exe, ldrmodules and dlllist list no module at the injected address, so the code is hidden from the normal loaded-module lists.

3.2 Network connections

The connections plugin shows one active TCP session, and connscan, which scans memory for connection structures, also finds a second, already closed session. Both belong to explorer.exe, and **no other process has a connection to a remote host**. Port 8080 is a common alternate HTTP port, often used by command-and-control traffic to blend in with web traffic.

```
> vol -f project1-c.vmem --profile=WinXPSP3x86 connscan
Offset(P)  Local Address             Remote Address            Pid
0x02087620 172.16.112.128:1038       41.168.5.140:8080         1484
0x023a8008 172.16.112.128:1037       125.19.103.198:8080       1484
```

3.3 Remote hosts

IP address	Location	Network owner	Role
41.168.5.140	Johannesburg, Gauteng, South Africa	AS36937 Liquid Telecommunications South Africa	Active connection from explorer.exe on port 8080
125.19.103.198	Kota, Rajasthan, India	AS9498 Bharti Airtel Ltd.	Closed connection from explorer.exe on port 8080
188.40.0.138	Falkenstein, Saxony, Germany	AS24940 Hetzner Online GmbH (hosting)	Probable command-and-control address found in process memory (see 3.7)

IP geolocation is approximate, and these addresses may belong to compromised third-party machines or relays. They show where the hosts are, not necessarily where the attacker is.

3.4 Sockets and timeline

Fifteen sockets were found, and sockscan returned the same set. Fourteen of them were created during system start-up (02:42:31 to 02:43:01) and belong to well-known Windows services. The only exception is **TCP port 1038 owned by explorer.exe, created at 02:44:45**, about 104 seconds after the last service socket and 23 seconds before the image was captured. It matches the active connection to 41.168.5.140:8080.



Owner	Sockets	Created (UTC)	Assessment
System (4)	TCP 445, 139; UDP 445, 137, 138	02:42:31 - 02:42:38	Normal SMB / NetBIOS
lsass.exe (664)	UDP 500, 4500; protocol 255	02:42:53	Normal IKE / IPsec
svchost.exe (908, 1004, 1220)	TCP 135; UDP 123; UDP 1900	02:42:33 - 02:43:01	Normal RPC, time, SSDP
alg.exe (788)	TCP 1028 on 127.0.0.1	02:43:01	Normal, loopback only
explorer.exe (1484)	**TCP 1038**	**02:44:45**	**Suspicious: matches the connection to 41.168.5.140:8080**

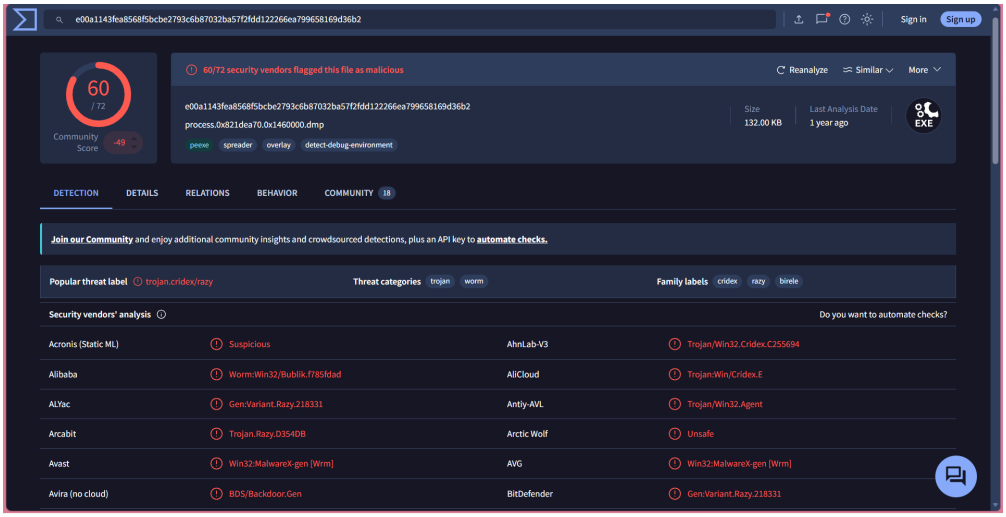
The closed connection on local port 1037 no longer has a socket object. Since Windows XP assigns ephemeral ports sequentially, it was probably opened shortly before port 1038, but its creation time could not be recovered, so this ordering is an inference.

3.5 Malware artifacts and VirusTotal

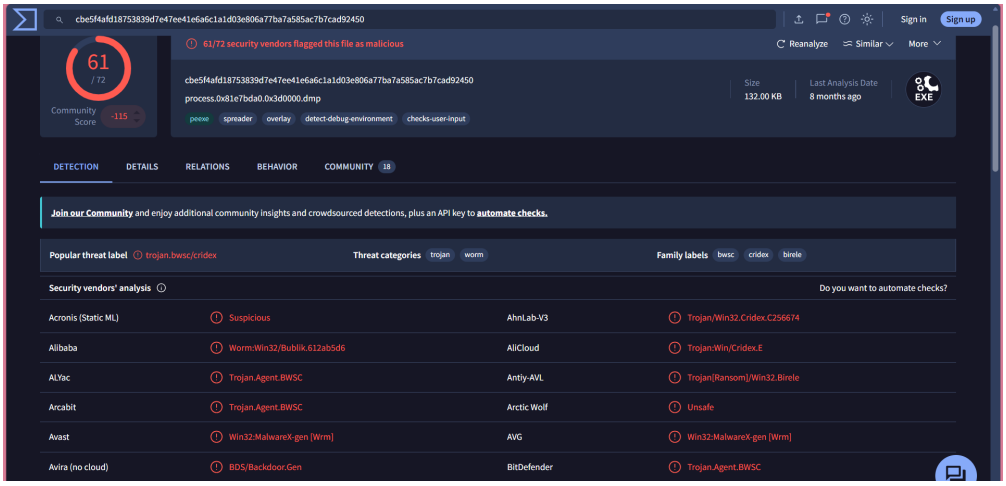
For both suspicious processes, the process image was dumped with procdump and the injected region with malfind -D. All four files were hashed with certutil, and the hashes were looked up on VirusTotal (results are stored analyses from earlier scans, not new uploads).

Process	Artifact	SHA-256	VirusTotal
explorer.exe	Injected region (132 KB)	e00a1143fea8568f5bcbe2793c6b87032ba57f2fdd122266ea799658169d36b2	**60 / 72** - trojan.cridex/razy (Microsoft: Worm:Win32/Cridex.E)
explorer.exe	Process image (1009.5 KB)	48db195007e5ae9fc1246506564af154927e9f3fbfca0b4054552804027abbf2	34 / 70 - generic labels (multiop, PUA); no Cridex name
reader_sl.exe	Injected region (132 KB)	cbe5f4afd18753839d7e47ee41e6a6c1a1d03e806a77ba7a585ac7b7cad92450	**61 / 72** - trojan.bwsc/cridex (AhnLab: Trojan/Win32.Cridex.C256674)
reader_sl.exe	Process image (28.5 KB)	5b136147911b041f0126ce82dfd24c4e2c79553b65d3240ecea2dcab4452dcb5	20 / 58 - generic labels (multiop, PUA); no Cridex name

Interpretation. The injected regions are clearly malicious: many independent vendors agree on the **Cridex** family. The process images received only generic labels from fewer engines and should not be called Cridex. This is expected, because the payload lives in the injected region, while the process image is the host program, rebuilt from memory.



VirusTotal result for the region injected into explorer.exe: 60/72, trojan.cridex/razy.



VirusTotal result for the region injected into reader_sl.exe: 61/72, trojan.bwsc/cridex.

3.6 Banking-related strings

The memory of explorer.exe (about 90 MB) was dumped with memdump, and URLs were extracted with a PowerShell regular expression. Besides many Microsoft and certificate-revocation URLs from system libraries, the dump contains URLs of financial institutions, including login pages and logos. The Windows shell has no reason to hold these, and they fit the web-inject templates that banking trojans use to imitate or modify banking pages and steal credentials.

```
PS> Select-String -Path urls.txt -Pattern "mfasa|tdbank|authorize"
urls.txt:60:https://account.authorize.net/UI/themes/anet/images/authorizenet_logo.gif\"/><iframe
urls.txt:61:https://account.authorize.net/UI/themes/anet/logon2.aspx\"
urls.txt:75:https://mfasa.chase.com/auth/fcc/login"
urls.txt:76:https://onlinebanking.tdbank.com/images/TDBankLogo.gif'
urls.txt:77:https://onlinebanking.tdbank.com/images/TDBankLogo.gif"
```

Institution	Examples found in the process memory
JPMorgan Chase	http://www.chase.com/ ; https://chaseonline.chase.com/gw/secure/ena ; https://mfasa.chase.com/auth/fcc/login
TD Bank	https://onlinebanking.tdbank.com/images/TDBankLogo.gif
Authorize.net (payment gateway)	https://account.authorize.net/UI/themes/anet/logon2.aspx

3.7 Probable command-and-control address

Among the IP addresses extracted from the dump, **188.40.0.138** stands out because it also appears in a full URL on the same port used by the observed connections, pointing to a PHP script:

```
http://188.40.0.138:8080/zb/v_01_a/in/cp.php
```

This looks like a command-and-control gate address stored in the malware configuration. It was not an active connection when the image was captured, and it belongs to a hosting provider (Hetzner, Germany), so the link to the infection is an inference from the URL structure and port. Other public addresses found in the dump (190.81.107.70, 210.56.23.100, 211.44.250.173, 216.246.75.83, 85.214.204.32) were not verified.

4. Putting it together

The evidence is consistent with a Cridex infection that started with the spearphishing attachment. The same payload is present inside explorer.exe and the Adobe Reader component reader_sl.exe. explorer.exe is the process that communicates with the attacker, and its connection was opened less than half a minute before the memory capture. Adobe Reader is a plausible entry point for a malicious document, but reader_sl.exe started in the same second as explorer.exe, which suggests it is launched at logon. **The memory image alone cannot prove which process was infected first.**

5. Indicators of compromise

Type	Value
Processes	explorer.exe (PID 1484), injected region 0x01460000; reader_sl.exe (PID 1640), injected region 0x003d0000
SHA-256 (payload, explorer.exe)	e00a1143fea8568f5bcbe2793c6b87032ba57f2fdd122266ea799658169d36b2
SHA-256 (payload, reader_sl.exe)	cbe5f4afd18753839d7e47ee41e6a6c1a1d03e806a77ba7a585ac7b7cad92450
IP addresses	41.168.5.140:8080 ; 125.19.103.198:8080 ; 188.40.0.138:8080

Type	Value
URL	http://188.40.0.138:8080/zb/v_01_a/in/cp.php

6. Recommendations

- Isolate the machine and block the listed IP addresses and URL at the firewall and proxy.
- Reset the credentials of affected accounts, especially financial ones, and enforce multi-factor authentication.
- Review the original email and attachment, and scan other machines for the same hashes and connections.
- Restrict execution and monitor for RWX memory allocation and injection behavior with an EDR tool.
- Reinforce phishing-awareness training and attachment filtering.

7. Limitations

The findings come from a single memory image. The initial infection vector could not be recovered from memory, IP geolocation is approximate, VirusTotal results reflect previously stored analyses, and the link between 188.40.0.138 and the infection is an inference. Commands in this report are shortened (the full path to the evidence file is omitted).